

HACKER WOMEN COUNCIL — ETHICAL HACKING

Actividad 01 - Análisis y planificación del pentest

Karen Itzel Jaime Castillo

Escenario: Aurora Market ( Tu tienda. Tu confianza. Tu seguridad.)

1. OBJETIVO DEL PENTEST

Define 3 objetivos concretos que tendría la evaluación de seguridad de Aurora Market.

1. Evaluar la aplicación web de Aurora Market para descubrir fallos de seguridad (como problemas de autenticación, control de accesos) antes de que un atacante real los encuentre.
 2. Comprobar el nivel de información de los clientes (nombres, correos, teléfonos, direcciones e historial de compras) al que podría acceder un usuario no autorizado ya sea por errores de configuración o permisos.
 3. Proponer directrices de mitigación: Entregar recomendaciones claras y prácticas para que el equipo de desarrollo corrija los hallazgos y fortalezca la postura de seguridad general de la plataforma.
-

2. ALCANCE (SCOPE)

Identifica claramente qué se evaluará y qué queda fuera del alcance.

SÍ SE EVALUARÁ (Sistemas o elementos incluidos):

- La plataforma web de comercio electrónico de Aurora Market (aplicación web autorizada).
- Los mecanismos de autenticación y control de usuarios.
- La base de datos y flujos de consulta de pedidos e información de clientes involucrados en la aplicación web.

❌ FUERA DEL ALCANCE (Elementos excluidos):

- Redes sociales de la empresa.
 - Equipos personales, cuentas de correo o dispositivos de los empleados.
 - Proveedores externos u otros sistemas tecnológicos que no formen parte de la plataforma acordada.
 - Pruebas de denegación de servicio que puedan interrumpir el negocio o afectar la información real de los clientes.
-

3. AUTORIZACIÓN Y CONDICIONES

Explica qué permisos y condiciones deben estar definidos antes de comenzar las pruebas.

-  **Permisos requeridos:**
 - Autorización formal por escrito firmada por la dirección de Aurora Market para realizar las pruebas de penetración.
 - Carta de liberación de responsabilidad que delimite el marco legal del ejercicio ético.
 - Credenciales de prueba (usuarios de distintos roles) proporcionadas por el cliente para evaluar la lógica de privilegios.
 -  **Condiciones acordadas:**
 - Las pruebas se realizarán estrictamente sobre la aplicación web autorizada.
 - Se ejecutarán en horarios de menor actividad para mitigar cualquier impacto operativo.
 - Compromiso de confidencialidad absoluta sobre los datos de los clientes y hallazgos encontrados.
 - Definir un Plan de Respuesta a Incidentes
-

4. TIPO DE PENTEST

Determina si el escenario corresponde a un Black-box, Gray-box o White-box. Investiga brevemente el concepto y justifica tu elección.

Tipo de pentest elegido: Gray-box

 BLACK-BOX	 GRAY-BOX	WHITE-BOX
Sin conocimiento previo de la infraestructura o código.	El evaluador tiene información parcial, como credenciales o datos de la aplicación. Aurora Market entrega información parcial (credenciales, roles, endpoints). Simula un atacante con ciertos accesos internos o visión semi-pública, optimizando tiempos.	Acceso total a arquitectura y código fuente.

Justificación de la elección:

Aurora Market entrega información parcial al equipo de seguridad. Se sabe que existe una aplicación web, una base de datos y mecanismos de autenticación con distintos roles, pero no se conoce todo el código fuente ni los detalles profundos de la arquitectura de construcción. Esto simula de manera realista a un atacante con ciertos privilegios internos o información semi-pública, optimizando el tiempo de evaluación.

5. PLANIFICACIÓN

Establece qué debería hacer el equipo antes de comenzar la parte técnica. Completa los elementos clave.

-  **Objetivos:** Definir el enfoque hacia la identificación de riesgos en autenticación y fuga de datos de usuarios.
-  **Alcance:** Delimitación exclusiva al entorno web de Aurora Market sin tocar redes sociales ni infraestructura de terceros.
-  **Permisos y condiciones:** Obtención de la carta de autorización formal y definición de ventanas de mantenimiento en horarios de baja afluencia.
-  **Metodología a utilizar:** Estándares reconocidos de pruebas de intrusión (como OWASP Testing Guide).

- 🔍 **Recopilación de información previa:** Análisis de huella digital (footprinting), revisión de endpoints expuestos y flujos de inicio de sesión.
- 💻 **Recursos necesarios:** Entorno de pruebas, herramientas de interceptación de tráfico, escáneres de vulnerabilidades autorizados.
- 📅 **Programación del pentest:** Calendarización de las fases de ejecución respetando las ventanas de tiempo acordadas.

🎯 6. FASES DEL PENTEST

Explica cómo aplicarías cada fase al caso de Aurora Market. ¿Qué buscarías hacer en cada etapa?

1. 🕵️ **Reconocimiento:** Recopilar información pública de Aurora Market, identificar tecnologías visibles en la plataforma web y mapear las rutas de la tienda y los paneles de usuario *Burp Suite* para la interceptación de tráfico, *Nmap* para el descubrimiento de puertos en la fase de reconocimiento, *OWASP ZAP* para la automatización inicial de escaneos.
2. 🔍 **Análisis de vulnerabilidades:** Buscar fallos conocidos en los formularios de registro, validación de entradas y en el reporte de atención a clientes que motivó la auditoría.
3. 🗝️ **Explotación:** Intentar comprobar de manera controlada si las vulnerabilidades detectadas (por ejemplo, fallos de control de acceso horizontal o vertical) permiten ver información perteneciente a otra cuenta, tal como reportó el usuario.
4. 🏰 **Post-explotación:** Evaluar hasta dónde podría escalar privilegios un atacante dentro de la plataforma con la información obtenida, manteniendo siempre la integridad de los datos.
5. 📄 **Informe:** Documentar detalladamente cada hallazgo con su nivel de criticidad, evidencia y pasos de reproducción para entregarlo al equipo de desarrollo.

📖 7. INVESTIGACIÓN

Consulta al menos una de las metodologías que revisamos en clase y explica por qué podría ser útil para este proyecto.

METODOLOGÍA ELEGIDA:	¿POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?:
<i>OWASP Top 10 / OWASP Web</i>	<i>Porque está diseñada específicamente para</i>

Security Testing Guide (WSTG).

aplicaciones web de comercio electrónico como Aurora Market. Proporciona un marco estandarizado y exhaustivo para evaluar los riesgos más críticos en la web (como control de accesos rotos, fallas criptográficas o inyecciones), asegurando que ninguna vulnerabilidad clave en la gestión de usuarios o datos personales quede sin revisar.



Nombre completo: Karen Itzel Jaime Castillo

Fecha: 28/08/2026